écentic — GDPR Compliance Memo

Last updated: 2026-06-02 **For:** Investor / Enterprise diligence **Scope:** EU General Data Protection Regulation (Regulation (EU) 2016/679) + Albanian Law No. 9887

Summary

écentic operates as a **data processor** for our merchant customers' data, and as a **data controller** for our own user data (account holders, marketing contacts, support correspondents). Our compliance posture is built around three principles: minimum data collection, transparent processing, and merchant control.

Data flows in the product

Flow

Source

Destination

Classification

Controller / Processor

Merchant signs up

Web form

écentic DB

Personal data (account holder)

écentic = controller

Store connects via OAuth

Merchant’s Shopify

écentic DB

Mixed: account holder + store metadata

écentic = controller for account data; processor for store data

Catalog sync

Merchant’s store

écentic DB

Business data (product info — not personal)

écentic = processor

Agent traffic beacon fires

End-shopper’s browser

écentic DB

Anonymized request metadata (not personal data of the shopper)

écentic = processor on behalf of merchant

Simulation runs

écentic DB

AI provider APIs (Azure, OpenAI, Anthropic, Google, Perplexity)

Catalog content + competitor URLs

écentic = processor (sub-processed to AI providers)

Optimized listing publishes

écentic DB

Merchant’s store

Generated listing content

écentic = processor

Win-rate dashboard renders

écentic DB

Merchant’s browser

Account holder + aggregated business data

écentic = controller for the account holder UX; processor for the store data shown

Roles defined

Data controller (Art. 4(7) GDPR): écentic shpk, for our user accounts, marketing contacts, support records.

Data processor (Art. 4(8) GDPR): écentic shpk, for the merchant’s store and catalog data we process on their behalf.

Joint controllership (Art. 26): Not applicable. Our position is unambiguous controller-vs-processor depending on the data category.

Lawful bases (Art. 6) we rely on

Activity

Lawful basis

Operate the service for a paying merchant

Contract (Art. 6(1)(b))

Bill the merchant

Contract + Legal obligation (Art. 6(1)(b) + (c))

Service notifications

Contract

Aggregate anonymized industry benchmarks

Legitimate interest (Art. 6(1)(f)), with the necessary balancing test documented

Marketing emails

Consent (Art. 6(1)(a)), opt-in only

Detect fraud / abuse

Legitimate interest

We do not process special categories of data (Art. 9) and do not perform automated decision-making producing legal effects (Art. 22).

Sub-processors

A current sub-processor register is maintained and available to customers on request. Material sub-processors include:

Sub-processor

Location

Purpose

Transfer mechanism

Vercel

US + EU regions

Application hosting

EU region selectable; SCCs in place for US fallback

Managed PostgreSQL (EU region)

EU

Database

No transfer outside EEA

Microsoft Azure AI Studio

EU and US regions

Production LLM gateway

SCCs in place

OpenAI

US

LLM API for simulation

SCCs; OpenAI’s enterprise terms confirm no training on customer data

Anthropic

US

LLM API for simulation

SCCs; Anthropic’s enterprise terms confirm no training on customer data

Google Vertex AI

EU + US regions

LLM API for simulation

SCCs

Perplexity API

US

LLM API for simulation

SCCs

Resend

US

Transactional email

SCCs

UploadThing

US + EU

File storage

EU region selectable; SCCs for US

Sentry

EU region

Error tracking

EU region used by default

PostHog

EU region

Product analytics

EU region used by default; cookie consent enforced

Any new sub-processor is added to the register, customers are notified 30 days in advance, and customers may object during that period.

Data subject rights — operational implementation

We have implemented engineering processes to respond to data-subject requests within the 30-day GDPR deadline:

Access / portability: Admin tool exports all personal data tied to a user account in JSON within 7 days.

Rectification: Self-service via the account settings UI for most fields; admin-assisted otherwise.

Erasure: Admin tool deletes a user account and all linked personal data. Aggregated and anonymized benchmark data is retained (not personal data after anonymization).

Restriction / objection: Manual workflow; engineering ticket triggered to restrict processing for the requesting subject.

Cross-border transfer mechanism

For US-hosted sub-processors (Vercel default deployment, OpenAI, Anthropic, Resend, UploadThing), we rely on the European Commission's Standard Contractual Clauses (Module 2 — controller to

processor) plus the supplementary measures recommended by the EDPB (encryption in transit and at rest, pseudonymisation where feasible, contractual restrictions on government data requests).

We have selected EU regions wherever available (Vercel, PostgreSQL host, UploadThing, Sentry, PostHog) to minimize transfer surface.

Data Protection Officer (DPO)

We are not legally required to appoint a DPO at our current scale (Art. 37 GDPR thresholds are not met — we are not a public authority, our core activities do not involve large-scale systematic monitoring of data subjects, and we do not process special categories of data at large scale). We have nonetheless designated the CEO (Xhurian Shaba) as the internal data-protection point of contact. We will reassess DPO appointment as the customer base scales.

Records of Processing Activities (Art. 30)

A current Article 30 register is maintained internally and available on request to customers and supervisory authorities. It enumerates all processing activities, lawful bases, retention periods, recipients, and transfer mechanisms.

Data Processing Addendum (DPA)

A standard DPA, compliant with Art. 28 GDPR, is incorporated by reference into every merchant agreement (Tier 1 self-serve and above) and is available for customer counter-signature. The DPA includes: - Definitions consistent with GDPR - Processor obligations under Art. 28(3) - Sub-processor list with notification obligation for changes - Standard Contractual Clauses (Module 2) where international transfers occur - Data subject rights cooperation - Audit rights - Breach notification obligations - Data return / deletion at end of contract

Breach response

In the event of a personal data breach (Art. 33–34 GDPR), our process is:

Internal escalation to CEO within 4 hours of detection.

Preliminary risk assessment within 24 hours.

Supervisory authority notification within 72 hours if a risk to rights and freedoms exists.

Affected data subject notification “without undue delay” if a high risk exists.

Post-incident review and Art. 33(5) record completed within 14 days.

No personal data breach has occurred as of 2 June 2026.

Annual review

This memo is reviewed annually (next review: June 2027) and updated when material changes occur (new sub-processor, new product capability handling personal data, new regulatory guidance, new geographic market).